

# SecureOrg Inc.

## PCI DSS Compliance Framework

# Access Control Policy

|                     |                                    |
|---------------------|------------------------------------|
| Document Reference: | ACP-003                            |
| Version:            | 2.0                                |
| Effective Date:     | April 14, 2026                     |
| Document Owner:     | Chief Information Security Officer |
| Classification:     | CONFIDENTIAL                       |
| Review Cycle:       | Annual                             |
| Framework:          | PCI DSS v4.0                       |

*This document contains confidential and proprietary information. Unauthorized disclosure is prohibited.*

## 1. Purpose and Scope

### 1.1 Purpose

This Access Control Policy defines the requirements for managing logical and physical access to SecureOrg Inc. systems, networks, applications, and cardholder data in compliance with PCI DSS v4.0 Requirements 7 and 8. The Policy establishes principles of least privilege, need-to-know, and separation of duties to protect cardholder data from unauthorized access.

### 1.2 Scope

This Policy governs access to all systems within the cardholder data environment (CDE) and connected systems, including on-premises infrastructure, cloud platforms, third-party services, and physical locations where CHD is processed or stored.

## **2. Access Control Principles**

### **2.1 Least Privilege**

Access rights shall be granted based on the minimum level of access required for users to perform their defined job responsibilities. Granting of access shall follow a default deny-all model, with explicit permissions granted only as justified by documented business need.

### **2.2 Need-to-Know**

Access to cardholder data and sensitive system information shall be restricted to individuals who have a documented, legitimate business need to access that specific data to perform their job functions. Job function alone does not constitute sufficient justification; access must be specifically required for defined tasks.

### **2.3 Separation of Duties**

Critical functions shall be divided to prevent any individual from having complete control over sensitive processes or data. Key separations include:

- No individual may both request and approve their own access
- System administrators of production CDE systems may not perform security audits of those same systems
- Developers shall not have access to production CDE environments
- Individuals with access to encryption keys shall not also be sole administrators of the data encrypted by those keys

## **3. User Access Management**

### **3.1 Access Provisioning**

Access to CDE systems and CHD shall be provisioned through the following process:

- The user's manager submits an access request through the IT service management system, specifying the systems, data, and permission levels required
- The system owner reviews and approves or denies the request based on business justification
- The Information Security team evaluates the request for compliance with least privilege and conflict of interest
- Approved access is provisioned by the Identity and Access Management (IAM) team

- The user receives notification and, where applicable, completes required training before access is activated
- Provisioning is documented in the access management system for audit purposes

### **3.2 Access Reviews**

Access rights shall be formally reviewed to ensure they remain appropriate:

- CDE system access: Reviewed every 6 months (minimum quarterly for privileged accounts)
- All other system access: Reviewed annually
- Management must confirm or revoke each access right in writing during reviews
- Any access not explicitly confirmed during a review is revoked

### **3.3 Access Modification**

Access shall be modified promptly when a user's role changes. Managers must notify the IAM team within one business day of any role change, promotion, transfer, or reassignment. The IAM team shall revoke previous access and provision new access appropriate to the new role within 24 hours of notification.

### **3.4 Access Termination**

Upon termination or resignation of an employee or contractor:

- HR notifies the IAM team immediately upon receiving a termination notice or resignation
- All system access shall be disabled within 24 hours of termination; immediately upon involuntary termination
- Physical access credentials (badges, keys) shall be collected at the time of departure
- All accounts and access rights are fully removed within 30 days of termination
- Terminated user accounts shall be reviewed for any anomalous activity in the 30 days prior to termination

## **4. Authentication Requirements**

### **4.1 Multi-Factor Authentication (MFA)**

Multi-factor authentication is required for the following access scenarios (per PCI DSS Requirement 8.4):

- All access to the cardholder data environment regardless of location
- All remote access to corporate networks
- All administrative access to CDE systems and network components
- All access to the cardholder data environment from outside the CDE perimeter

MFA must use at least two of the following factor categories: something you know (password/PIN), something you have (hardware token, authenticator app, smart card), or something you are (biometric). SMS OTP is not permitted for CDE access due to SS7 vulnerabilities.

## 4.2 Password Requirements

Password requirements are defined in the Password Policy (PWP-008). Minimum requirements for CDE access include:

- Minimum 12 characters for user accounts; 16+ characters recommended
- Complexity requirements: uppercase, lowercase, numbers, and special characters
- Maximum age: 90 days; minimum age: 1 day (prevents immediate reuse)
- Password history: last 12 passwords prohibited
- Account lockout after 6 failed attempts with 30-minute lockout duration

## 4.3 Service and System Accounts

Service accounts and system-to-system authentication shall adhere to the following:

- Service accounts shall use unique credentials not shared with any user accounts
- Service account passwords shall be rotated every 90 days or upon personnel changes
- API keys and service tokens shall be stored in approved secrets management systems, never in code
- Service accounts shall have only the minimum permissions required for their function

# 5. Privileged Access Management

## 5.1 Privileged Account Controls

Administrative and privileged accounts require enhanced controls due to the elevated risk they present:

- Privileged access activities shall be logged with sufficient detail to reconstruct actions taken

- Privileged accounts shall be separate from standard user accounts (no dual-use accounts)
- Privileged access sessions to CDE systems shall be conducted through a Privileged Access Workstation (PAW) or approved jump server
- Just-in-time (JIT) access shall be implemented for privileged operations where feasible
- Privileged account usage shall be reviewed weekly by the Information Security team

## 5.2 Root and Superuser Access

- Direct root or superuser login to production systems is prohibited; users shall sudo or use equivalent mechanisms from named accounts
- Root account credentials shall be stored in a secured break-glass vault with access logged and alerted
- Use of root-level access shall require a documented change or incident ticket reference

## 6. Remote and Third-Party Access

### 6.1 Remote Access Controls

Remote access to CDE systems is subject to the following requirements beyond standard authentication:

- Vendor and third-party remote access shall be enabled only when needed and disabled immediately after use
- All remote access sessions shall be monitored and logged
- Remote access sessions to the CDE shall time out after 15 minutes of inactivity
- Third parties shall use unique credentials; shared credentials are prohibited

### 6.2 Third-Party Access

Vendors, service providers, and business partners requiring access to CDE systems or CHD must:

- Execute a formal access agreement specifying their security responsibilities
- Provide evidence of PCI DSS compliance or undergo a security assessment
- Use MFA for all access without exception
- Have their access reviewed and renewed at least annually
- Be notified that their access is subject to monitoring and logging

## 7. Physical Access Controls

### 7.1 Physical Access to CDE

Physical access to data centres, server rooms, and other locations housing CDE components shall be controlled through:

- Electronic access control systems with individual, unique access credentials per person
- Visitor logs maintained for all non-permanent personnel with date, time, and business purpose
- Escort requirements for visitors and third parties in CDE locations
- Video surveillance covering all entry and exit points, with footage retained for 90 days minimum
- Access logs reviewed at least monthly and upon any security incident

## 8. Revision History

|     |              |                                                                                |               |
|-----|--------------|--------------------------------------------------------------------------------|---------------|
|     |              |                                                                                |               |
| 1.0 | Jan 15, 2024 | Initial release                                                                | CISO Office   |
| 1.5 | Aug 1, 2024  | Added MFA requirements per PCI DSS v4.0 Req 8.4; third-party access section    | Security Team |
| 2.0 | Apr 14, 2026 | Annual review; privileged access management expansion; physical access updates | CISO Office   |